TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

APT29-linked watering holes serve patched n-day exploit chains to iPhones and Android phones

From **Cybersecurity Briefing** · 2026-11-02 to 2026-11-07 · Briefing generated 2026-11-07

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261112-03	1.0 · 2026-11-12 15:03 EST	TLP:CLEAR	Global
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-04	2026-11-05	CVE-2025-43529 (CVSS 8.8), CVE-2024-27834 (CVSS 5.5), CVE-2026-20700 (CVSS 7.8), CVE-2025-14174 (CVSS 8.8), CVE-2025-43510 (CVSS 7.8), CVE-2025-43520 (CVSS 5.5), CVE-2026-3910 (CVSS 8.8), CVE-2025-27038 (CVSS 7.5)	Nick Sturgeon

NATION-STATE | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 4 November 2026 the French firm Sekoia published research on a campaign it calls Poisoned Source, found in mid-October 2026. Sekoia assesses with moderate to high confidence that APT29 (Midnight Blizzard, Cozy Bear), or one of its subgroups, is behind it [S1] [S3]. The operators reached phones three ways: JavaScript injected into legitimate websites, lookalike domains that reverse-proxy real sites while adding a malicious script, and a week-long compromise (27 August to 3 September 2026) of the Ukrainian analytics tracker Plerdy, which thousands of mostly Ukrainian websites load [S1] [S3] [S4]. Affected sites include a Ukrainian gas producer, a US chemical industry trade association, Czech and other European far-right political sites, a Bulgarian military-related site, and clones of the America250 site and of the Raffles London at The

OWO hotel site [S1] [S2].

A fingerprinting script profiles each visitor and the server returns one of three exploit chains with no user interaction. Class A hits iOS 16.7 and steals cookies (CVE-2025-43529, CVE-2024-27834). Class B hits iOS 18.5 with the DarkSword kit and takes messages, mail, Keychain, Wi-Fi keys, photos and more (CVE-2025-43529, CVE-2026-20700, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520). Class C hits Android Chrome 139 to 145 (not 143) and drops a payload Sekoia calls AndroSnitch that takes Chrome cookies, saved logins, history and Wi-Fi configuration (CVE-2026-3910, CVE-2025-27038) [S1] [S4]. None of the payloads persist. Every flaw was already patched, and seven of the eight were already in the CISA Known Exploited Vulnerabilities catalog; CISA added the eighth, CVE-2024-27834, on 4 November 2026 with a federal due date of 18 November 2026 [S5] [S7] [S8] [S9] [S10] [S11] [S12] [S13] [S14].

This report updates the earlier reports CTI-20261104-03 and CTI-20261105-03, which carried no indicators. Sekoia's public write-up was reachable this time and gives delivery, proxy and exfiltration domains, five IP addresses, sample hashes and the exfiltration endpoint on TCP 8881 [S1]. Sekoia withholds its full indicator set for its own customers and for national CERTs and law enforcement on request, so the list here is partial. Sekoia did not establish how many phones were compromised, and it is not clear whether the operators wanted specific people or as many vulnerable devices as possible; the scripts had no target filter [S1] [S2] [S3].

Action: bring managed iPhones to the newest iOS release available for the device (iOS 26.3 or later closes every Apple flaw in the DarkSword chain) and Android Chrome to 146.0.7680.75 or later along with current Android security patches, block and hunt for the listed domains and IPs, and treat any phone that ran a vulnerable build and contacted this infrastructure as having lost its cookies and stored credentials [S1] [S8] [S12].

Key judgments

LIKELY · MODERATE CONFIDENCE
It is likely that the same operators will stand up new delivery and exfiltration domains and keep running mobile watering holes now that the current infrastructure is public, because the method relies on cheap, repackaged n-day chains and the delivery domains were registered in several batches between April and August 2026. [S1] [S4]

VERY LIKELY · MODERATE CONFIDENCE
Other groups, including criminal ones, are very likely to keep using DarkSword-family and similar packaged exploit kits against phones that lag on updates; reporting already ties DarkSword and the related Coruna kit to a separate criminal ad-tag campaign across hundreds of domains. [S1] [S4]

> **UNLIKELY · LOW CONFIDENCE**
> It is unlikely that most Indiana organizations were deliberately targeted, but opportunistic compromise of an out-of-date phone belonging to someone who visited an affected US site (the chemical trade association or the America250 lookalike) is a realistic possibility because the scripts applied no victim filter. [S1] [S2] [S3]

> **LIKELY · MODERATE CONFIDENCE**
> Stolen session cookies and saved passwords will likely be used for follow-on access to webmail and cloud services, since cookie theft is the common goal across all three chains and matches the 2024 Mongolia watering hole that Google linked to the same actor. [S1] [S3] [S4]

> **ALMOST CERTAIN · HIGH CONFIDENCE**
> Fully patched iOS and Android Chrome devices are almost certain to be safe from these specific chains; the residual risk sits with devices that cannot or do not take current updates. [S1] [S2] [S3]

INDICATORS OF COMPROMISE

All campaign indicators come from Sekoia's public write-up of 4 November 2026 [S1]; one extra domain from The Hacker News belongs to a separate criminal campaign and is marked as such. Sekoia says it withheld part of its indicator set, the infrastructure may already be offline or rotated, and its article gives two different hash sets for some stages, so both are listed.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`static[.]flux-telemetry[.]com`	Delivery host for the fingerprinting script (UltimateFingerprinter) and exploit stages. Registered 2 April 2026, hosted at Shock Hosting (AS395092).	REPORTED	2026-04-02	[S1]
ipv4	`109[.]104[.]106[.]107`	Resolution of static.flux-telemetry.com (AS395092, Shock Hosting LLC).	REPORTED		[S1]
domain	`edge-ord[.]clouds-stacks[.]com`	Delivery host used in the Plerdy injection; redirected requests to other delivery servers and is assessed by Sekoia to be a load balancer. Registered 26 August 2026.	REPORTED	2026-08-26	[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`95[.]133[.]231[.]28`	Resolution of edge-ord.clouds-stacks.com (AS219399, servinga GmbH).	REPORTED		[S1]
domain	`ad[.]starx-net[.]com`	Exfiltration host for all three chains and host of the Class B stages. Registered 3 April 2026.	REPORTED	2026-04-03	[S1] [S4]
ipv4	`195[.]58[.]140[.]105`	Resolution of ad.starx-net.com (AS395092, Shock Hosting LLC).	REPORTED		[S1]
domain	`adsprism-stat[.]com`	Malicious script delivery domain used by the America250 lookalike site.	REPORTED		[S1]
domain	`america250[.]holiday`	Lookalike of america250.org that reverse-proxies the real site and adds the malicious script. Registered 19 May 2026.	REPORTED	2026-05-19	[S1] [S4]
ipv4	`192[.]121[.]46[.]25`	Hosting IP of america250.holiday (EDIS GmbH, AS9009 as reported).	REPORTED		[S1]
domain	`theowo[.]club`	Lookalike of the Raffles London at The OWO hotel site, reverse proxy, offline at the time of Sekoia's report. Registered 18 June 2026.	REPORTED	2026-06-18	[S1]
ipv4	`188[.]190[.]17[.]232`	Hosting IP of theowo.club (EDIS GmbH, AS57169).	REPORTED		[S1]
domain	`ads-it-assets[.]com`	Named by Sekoia as a server that edge-ord.clouds-stacks.com redirected to. Not in Sekoia's IOC table; role beyond redirect target not described.	REPORTED		[S1]
domain	`cdn[.]adv-static[.]com`	Named by Sekoia as a server that edge-ord.clouds-stacks.com redirected to. Not in Sekoia's IOC table.	REPORTED		[S1]
domain	`wpvortex-mod[.]com`	Named by Sekoia as a server that edge-ord.clouds-stacks.com redirected to. Not in Sekoia's IOC table.	REPORTED		[S1]
domain	`assets-int[.]com`	Named by Sekoia as a server that edge-ord.clouds-stacks.com redirected to. Not in Sekoia's IOC table.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
url	`hxxps[://]a[.]plerdy[.]com/public/js/click/main[.]js`	Legitimate Plerdy tracker script that carried injected code from 27 August to 3 September 2026 only. Do not block; use for retrospective log review of that window.	REPORTED	2026-08-27	[S1] [S4]
url	`hxxps[://]static[.]flux-telemetry[.]com/module/5b4c8fea5cbcee273e8d830f52-temfp[.]js`	Fingerprinting script (UltimateFingerprinter) loaded by injected pages.	REPORTED		[S1]
url	`hxxps[://]static[.]flux-telemetry[.]com/api/uGmlx2pmMHU1jq7wZU2QWgeC28vbXalf/v1`	Example of the endpoint that receives the fingerprint by POST and returns JavaScript. The middle path segment is a random nonce, so match on the pattern, not this exact value.	REPORTED		[S1]
url	`hxxps[://]ad[.]starx-net[.]com:8881/telemetry/v12`	Exfiltration endpoint used by Class A, B and C payloads.	REPORTED		[S1] [S4]
http-request	`POST /api/<nonce>/v1 with Content-Type: application/json (JSON body of about 394 fingerprint fields) to static.flux-telemetry.com; follow-on GETs to /api/<nonce>/v2 and /v3 on ad.starx-net.com`	Request pattern of the fingerprint upload and the Class B stage fetches as described by Sekoia. The pattern form is generalized from the reported example URLs.	DERIVED		[S1]
http-request	`POST /telemetry/v12 on port 8881 with request headers Filename and X-Device-Id`	Android AndroSnitch payload uploads files with libcurl using these hardcoded header names; the header value was not published.	REPORTED		[S1]
port	`8881/tcp`	Non-standard port of the exfiltration endpoint on ad.starx-net.com.	REPORTED		[S1] [S4]
filename	`5b4c8fea5cbcee273e8d830f52-temfp.js`	File name of the fingerprinting script.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`VDGH_TOKEN_REF`	Cookie name set by the malicious script as a replay guard so a visitor is processed once. Its presence in a mobile browser's cookie store for an affected site indicates exposure to the script.	REPORTED		[S1]
other	`UltimateFingerprinter / collectAndDisplayFingerprint() / adfp`	Class, function and variable names in the fingerprinting JavaScript. Useful for site owners searching their own templates and third-party scripts for injected code.	REPORTED		[S1]
other	`_0x3af331`	Obfuscated variable name in the code injected into the Plerdy tracker.	REPORTED		[S1]
other	`ASDhdhashdasads() / AHSDhdashashs()`	Function names in the iOS payload (process sweep and collector).	REPORTED		[S1]
other	`category: "only_cookies"`	Key and value in the JSON object the Class A payload sends when exfiltrating cookies (also description and path set to only_cookies, with a deviceUUID field).	REPORTED		[S1]
sha256	`493f8d0a9f0f89c51f74d5f1b5592871bf974b16035e43d202ea91ff12e5dfd4`	DarkSword kit sample uploaded to VirusTotal in September 2026, referenced by Sekoia.	REPORTED	2026-09	[S1]
sha256	`a7d2493df00565c21587b0cad2a9fe7ca1e5590acf796da6e499be0ffde44cc3`	Class A stage 1 (iOS 16.7 chain), from Sekoia's IOC table.	REPORTED		[S1]
sha256	`bee3e014e3df87ddce0250b0985b87f6868a427a7b650a74b7ffedb9d57f3088`	Class A stage 2 (iOS 16.7 chain); appears in both the body and the IOC table.	REPORTED		[S1]
sha256	`c170fda024183645c0aa681149304e50506509c3498bb6b9a5f5ced6aa73e5fa`	Class B stage 1 (/v1, iOS 18.5 DarkSword chain) as listed in Sekoia's IOC table. The article body gives a different hash for /v1 (next entry).	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`35c0cd19a7334b544c193e392bcd9a8f1d1f43cf6b61be5bf1d9e35537aff2ef`	Class B /v1 as listed in the article body. Differs from the IOC table value; Sekoia does not explain the difference (possibly a different capture or build).	REPORTED		[S1]
sha256	`2ffb35e3f9e55286a930fb887e73764a913166648135fe0ca7551736d97d7bfa`	Class B stage 2 (/v2) as listed in Sekoia's IOC table.	REPORTED		[S1]
sha256	`621112712ec515e8791129c62feda8fff6654a0116882401609503cacc08054a`	Class B /v2 as listed in the article body. Differs from the IOC table value.	REPORTED		[S1]
sha256	`69b6cb327a4d5da99399718f6a66f84de69f89425b0a31f2dcee0682f811596f`	Class B stage 3 (/v3); appears in both the body and the IOC table.	REPORTED		[S1]
sha256	`29d283ebd08d0cd3b2e6f4a67718d3d6e7a6be01d0613d716bce218dba57a928`	Class C stage 1 JavaScript (Android Chrome chain) as listed in Sekoia's IOC table.	REPORTED		[S1]
sha256	`ae3241d96cc2d99538c7aff60f382cc8dac13859bcbea3ee84992d24d22a8108`	Class C stage 1 for Chrome 139 to 144 as listed in the article body. Differs from the IOC table value.	REPORTED		[S1]
sha256	`41e6fd33a30d36dabff9ea408d9766a6583edcc107968f6dc1499f2586381967`	Class C stage 1 for Chrome 145, from the article body.	REPORTED		[S1]
sha256	`06c17b31d36838f3d29044784aa047d5c2d9174d3356c1211cf25f9df677445f`	Class C stage 2 JavaScript, from Sekoia's IOC table.	REPORTED		[S1]
sha256	`183d62d682aea8018491c8559544e8d6a9ab0e1abd05ecbb6c97daa4f438d2b8`	Class C stage 2 shellcode exploiting CVE-2025-27038 (Adreno GPU driver).	REPORTED		[S1]
sha256	`387a7fb768db1350a9788d9704e7a72abe07152734e0ff026af72b417e36268c`	AndroSnitch Android payload (internal name libexploit.so).	REPORTED		[S1]
filename	`libexploit.so`	Internal library name of the AndroSnitch payload.	REPORTED		[S1]
filepath	`/data/data/com.android.chrome/app_chrome/Default/Cookies`	Android file read and exfiltrated by AndroSnitch; the same directory's Login Data and History files are also taken. A collection target, not a dropped file.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/data/misc/apexdata/com.android.wifi/WifiConfigStore.xml`	Android Wi-Fi configuration (saved network keys) read by AndroSnitch; /data/misc/apns/0/WifiConfigStore.xml is also read.	REPORTED		[S1]
filepath	`/private/var/mobile/Containers/Data/Application/<UUID>/Library/Cookies/Cookies.binarycookies`	iOS per-app cookie store read by the iOS payloads; /var/mobile/Cookies/ is also read. A collection target, not a dropped file.	REPORTED		[S1]
filename	`wifi_passwords.txt`	File name used by the Class B payload when packaging stolen Wi-Fi keys for upload.	REPORTED		[S1]
other	`SM-S938B`	Device model string (Samsung Galaxy S25 Ultra) on which the Android chain exits without exploiting. Not an indicator of compromise; useful for understanding scope.	REPORTED		[S1] [S4]
domain	`ad-track[.]live`	NOT part of the APT29-linked campaign. Reported by The Hacker News as a DarkSword delivery domain in the separate criminal DeadTag ad-tag campaign; listed because it serves the same exploit kit family.	REPORTED		[S4]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The operators place a small script on pages that their intended audience visits, either by editing a legitimate site's template or JavaScript library, by tampering with a third-party tracker (Plerdy) that many sites load, or by running lookalike domains that reverse-proxy the real site and add the script. The script loads a fingerprinting component that collects roughly 394 browser and device attributes and posts them to the delivery server; obviously fake values (for example absurd screen sizes or no touch points) get an empty reply. For a matching phone the server returns JavaScript that runs one of three n-day exploit chains with no click: a WebKit code execution and pointer-authentication bypass on iOS 16.7 for cookie theft, the DarkSword chain on iOS 18.5 for full device collection, or a V8 code execution plus Adreno GPU driver sandbox escape on Android Chrome 139 to 145 that loads

the AndroSnitch payload. Data goes out over HTTPS to ad.starx-net[.]com on port 8881. Nothing is installed permanently, so the implant does not survive a restart, but the data is already gone by then [S1] [S3] [S4].

Threat actor

APT29 · also tracked as Midnight Blizzard, Cozy Bear, The Dukes

Attribution confidence: Moderate · **Motivation:** Espionage: collection of session cookies, credentials and device data from people tied to Ukraine, the United States and European politics and defense · **Suspected origin:** Russia; widely attributed to the Foreign Intelligence Service (SVR)

Attribution is Sekoia's alone, stated as moderate to high confidence and possibly a subgroup. It rests on overlap with the 2024 Mongolia watering hole that Google reported (same cookie-theft goal; the AndroSnitch name echoes Google's ANDROSNATCH), infrastructure habits, victimology, and CERT partners finding 2025 APT29 watering hole artifacts on one compromised site. Sekoia notes the exploits probably came from a third party, likely a commercial surveillance vendor, and that DarkSword is also used by unrelated actors. No government attribution has been published.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1583.001 Acquire Infrastructure: Domains	Registered delivery, exfiltration and lookalike domains between April and August 2026 across several hosting providers. [S1]	Flag newly registered or low-reputation domains with ad or telemetry themed names contacted from mobile devices; block the listed domains.
Resource Development	T1584.004 Compromise Infrastructure: Server	Compromised legitimate websites and edited the main template or an existing JavaScript library to load the attacker script. [S1] [S3]	File integrity monitoring on web templates and JavaScript assets; alert on new external script sources in served pages.
Resource Development	T1588.005 Obtain Capabilities: Exploits	Used packaged n-day chains, including the DarkSword kit, that Sekoia assesses were obtained from a third party. [S1] [S3]	Not directly detectable; track exploit kit reuse through threat intelligence.
Initial Access	T1189 Drive-by Compromise	Visitors to injected or cloned sites are exploited through the mobile browser with no interaction (ATT&CK for Mobile equivalent: T1456). [S1] [S2] [S3]	DNS and proxy logs for the delivery domains from mobile devices or guest and BYOD networks.

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	Tampered with the Plerdy tracker script (a.plerdy[.]com/public/js/click/main.js) from 27 August to 3 September 2026 so every site embedding it served the fingerprinting loader. [S1] [S3] [S4]	Inventory third-party scripts on owned sites; use Subresource Integrity and Content Security Policy reporting to catch changed or new script origins.
Credential Access	T1557 Adversary-in-the-Middle	Lookalike domains america250[.]holiday and theowo[.]club reverse-proxied the real sites and inserted the malicious script into the returned pages. [S1] [S3]	Brand and lookalike domain monitoring; block the listed domains.
Discovery	T1082 System Information Discovery	UltimateFingerprinter runs 61 collectors producing about 394 fields and posts them as JSON to choose the exploit chain by OS and browser version. [S1] [S4]	Large JSON POSTs to /api/<random>/v1 on unfamiliar hosts immediately after a page load.
Defense Evasion	T1497.001 Virtualization/Sandbox Evasion: System Checks	The server returns an empty 200 response to implausible fingerprints (extreme screen sizes, zero touch points); the Android chain exits on device model SM-S938B; a VDGH_TOKEN_REF cookie stops repeat processing. [S1] [S4]	Not practical on the endpoint; relevant to analysts trying to reproduce delivery.
Execution	T1203 Exploitation for Client Execution	WebKit use-after-free CVE-2025-43529 on iOS; V8 flaw CVE-2026-3910 on Android Chrome 139 to 145 (not 143). [S1] [S7] [S12]	MDM compliance reporting for iOS and Chrome versions below the fixed releases.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	Sandbox escape and kernel-level access through CVE-2024-27834 (PAC bypass), CVE-2026-20700, CVE-2025-14174, CVE-2025-43510 and CVE-2025-43520 on iOS, and CVE-2025-27038 (Adreno GPU driver) on Android. [S1] [S8] [S10] [S11] [S13] [S14]	Mobile threat defense tooling where deployed; otherwise rely on patch compliance.
Credential Access	T1539 Steal Web Session Cookie	All three chains take browser cookies: Cookies.binarycookies on iOS and the Chrome Cookies database on Android. [S1] [S3]	Identity provider logs for session reuse from new IPs or devices without a fresh sign-in.
Credential Access	T1555 Credentials from Password Stores	Class B reads the iOS Keychain and account stores; AndroSnitch reads Chrome Login Data; both take saved Wi-Fi keys. [S1] [S4]	Not observable on the device without forensic tooling; assume exposure and rotate.

Tactic	Technique	Procedure observed	Detection opportunity
Collection	T1005 Data from Local System	Class B collects SMS and iMessage, WhatsApp and Telegram databases, mail, contacts, call history, calendar, notes, Safari history, health and location data, photos and iCloud Drive files. [S1] [S2] [S4]	Unusually large uploads from a phone to an unfamiliar host shortly after web browsing.
Exfiltration	T1041 Exfiltration Over C2 Channel	HTTPS POST of collected data to ad.starx-net[.]com/telemetry/v12; Android uses libcurl with Filename and X-Device-Id headers. [S1]	Firewall and proxy logs for the exfiltration host and IP 195.58.140[.]105.
Command and Control	T1571 Non-Standard Port	Exfiltration endpoint listens on TCP 8881. [S1] [S4]	Outbound TLS to port 8881 from mobile, guest or VPN client address ranges.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

DNS lookups for Poisoned Source delivery, proxy and exfiltration domains `SIGMA`

```
title: Poisoned Source Mobile Watering Hole Domains
status: experimental
logsource:
  category: dns
detection:
  selection:
    query|endswith:
      - 'flux-telemetry.com'
      - 'clouds-stacks.com'
      - 'starx-net.com'
      - 'adsprism-stat.com'
      - 'america250.holiday'
      - 'theowo.club'
      - 'ads-it-assets.com'
      - 'adv-static.com'
      - 'wpvortex-mod.com'
      - 'assets-int.com'
  condition: selection
falsepositives:
  - Security tooling or analysts resolving the indicators
level: high
```

Run against DNS resolver, secure web gateway and Wi-Fi controller logs back to at least April 2026. Phones on cellular data will not appear; guest and BYOD networks matter most.

Network connections to campaign hosts or exfiltration port (Microsoft Defender XDR) `KQL`

```
let domains = dynamic(['flux-telemetry.com','clouds-stacks.com','starx-net.com','adsprism-
stat.com','america250.holiday','theowo.club','ads-it-assets.com','adv-static.com','wpvortex-mod.com','assets-int.com']);
let ips = dynamic(['109.104.106.107','95.133.231.28','195.58.140.105','192.121.46.25','188.190.17.232']);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteIP in (ips) or RemoteUrl has_any (domains)
| project Timestamp, DeviceName, InitiatingProcessFileName, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

Covers Defender-enrolled devices including mobile where Defender for Endpoint on iOS or Android is deployed. Extend the time range as retention allows; the IPs are shared-hosting addresses and may be reassigned.

TLS to exfiltration host on port 8881 `SURICATA`

```
alert tls $HOME_NET any -> $EXTERNAL_NET 8881 (msg:"HUNT Poisoned Source exfil host ad.starx-net.com on 8881"; flow:established,to_server;
tls.sni; content:"ad.starx-net.com"; nocase; endswith; classtype:trojan-activity; sid:9102611; rev:1;)
```

Matches the reported exfiltration endpoint by SNI. A broader hunt for any outbound TLS to port 8881 from phone address ranges can find rotated hosts but will be noisier.

Proxy hunt for fingerprint upload and telemetry paths `SPLUNK SPL`

```
index=proxy earliest=-90d
(url="*/telemetry/v12*" OR url="*-temfp.js*" OR (http_method=POST AND match(url, "/api/[A-Za-z0-9]{24,40}/v[123]$")))
| eval ua_mobile=if(match(http_user_agent, "(?i)iphone|android"), "yes", "no")
| where ua_mobile="yes"
| stats count min(_time) as first_seen max(_time) as last_seen values(url) as urls by src_ip, dest_host
| convert ctime(first_seen) ctime(last_seen)
```

Needs a proxy that inspects TLS or logs full URLs. Field names follow the Splunk Web data model and may need mapping. The path pattern is built from the reported URL format and could match unrelated APIs, so review the destination host.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS / iPadOS (WebKit) - Class A and Class B entry point	Chain observed against iOS 16.7 and iOS 18.5; flaw present before the fixed releases	iOS/iPadOS 18.7.3 and 26.2; Safari 26.2 (no iOS 16 or 17 fix listed in the CVE record)	CVE-2025-43529	8.8 (CISA ADP)	0.2565 (98th percentile, 2026-11-12)	Yes (added 2025-12-15)	Not retrieved (already passed)

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Apple iOS / iPadOS - Class A pointer authentication bypass	iOS 16.7 targeted; Sekoia says the chain works on iOS 16.0 to 17.4	iOS/iPadOS 16.7.8 and 17.5	CVE-2024-27834	5.5 (CISA ADP)	0.0150 (75th percentile, 2026-11-12)	Yes (added 2026-11-04)	2026-11-18
Apple iOS / iPadOS - Class B (DarkSword)	iOS 18.5 targeted; all versions before 26.3 listed as affected	iOS/iPadOS 26.3	CVE-2026-20700	7.8 (CISA ADP)	0.0165 (77th percentile, 2026-11-12)	Yes (added 2026-02-12)	Not retrieved (already passed)
ANGLE graphics layer (Google Chrome; also used in the iOS Class B chain)	Chrome before 143.0.7499.110; Apple fix version not retrieved	Chrome 143.0.7499.110; Apple fix issued alongside CVE-2025-43529 per the CVE record	CVE-2025-14174	8.8 (CISA ADP)	0.4326 (99th percentile, 2026-11-12)	Yes (added 2025-12-12)	Not retrieved (already passed)
Apple iOS / iPadOS kernel - Class B	iOS 18.5 targeted	iOS/iPadOS 18.7.2 and 26.1	CVE-2025-43510, CVE-2025-43520	7.8 and 5.5 (CISA ADP)	0.0037 and 0.0044 (2026-11-12)	Yes (both added 2026-03-20)	Not retrieved (already passed)
Google Chrome for Android (V8) - Class C	Chain targets Chrome 139 to 145, excluding 143; flaw present before 146.0.7680.75	Chrome 146.0.7680.75	CVE-2026-3910	8.8 (CISA ADP)	0.0268 (86th percentile, 2026-11-12)	Yes (added 2026-03-13)	Not retrieved (already passed)
Qualcomm Adreno GPU driver (Snapdragon Android devices) - Class C sandbox escape	Many Snapdragon platforms; see Qualcomm June 2025 security bulletin	Device vendor Android updates that include the Qualcomm June 2025 bulletin fixes (exact patch level not stated in the sources)	CVE-2025-27038	7.5 (Qualcomm)	0.0104 (65th percentile, 2026-11-12)	Yes (added 2025-06-03)	Not retrieved (already passed)

Immediate (0–24 hours)

- Block the listed delivery, proxy and exfiltration domains and the five IP addresses at DNS filtering, secure web gateway and firewall, including guest and BYOD Wi-Fi. Do not block a.plerdy[.]com; it is a legitimate service that was cleaned on 3 September 2026. `SOC` [S1]
- Search DNS, proxy and firewall logs back to April 2026 (or as far as retention allows) for the listed domains, IPs and outbound connections to port 8881, and identify the devices and users involved. `SOC` [S1]
- Pull an MDM compliance report of iPhones and iPads below iOS 18.7.3 / 26.3 and Android devices with Chrome below 146.0.7680.75 or a security patch level older than mid-2025, and push updates now. `IT OPS` [S1] [S7] [S8] [S12] [S13]
- For any phone that ran a vulnerable build and touched the listed infrastructure or one of the affected sites: restart it (derived from the lack of persistence), update it, revoke active sessions at the identity provider, reset passwords saved in the browser or Keychain, and change the keys of Wi-Fi networks stored on it. `SOC` [S1] [S2]

Short term (1–7 days)

- Enforce minimum OS and browser versions through MDM and conditional access so non-compliant phones cannot reach email and cloud apps. Use the CISA due date of 18 November 2026 for CVE-2024-27834 as the outer limit. `IT OPS` [S5] [S14]
- Review identity provider sign-in logs for the past 90 days for token or cookie replay: sessions continuing from new IPs, countries or device fingerprints without a new interactive sign-in. `SOC` [S1]
- If the organization runs public websites, check templates and JavaScript libraries for unexpected external script references and for the strings UltimateFingerprinter, temfp.js and flux-telemetry; confirm whether the Plerdy tracker was embedded during 27 August to 3 September 2026. `IT OPS` [S1] [S4]
- Tell staff who follow Ukraine, defense, chemical industry or America250 matters that the campaign used cloned and compromised sites, and ask them to update personal phones used for work. `LEADERSHIP` [S1] [S2]

Long term

- Retire phones that can no longer receive current iOS or Android security updates from any role with access to company data. iOS 16-only hardware is a specific concern because the CVE record lists no iOS 16 fix for CVE-2025-43529. `LEADERSHIP` [S1] [S7]
- Add Subresource Integrity, a Content Security Policy with reporting, and a reviewed inventory of third-party scripts to all owned websites so a tampered tracker cannot silently reach visitors. `IT OPS` [S1]
- Shorten session lifetimes and bind tokens to devices where the identity platform supports it, so stolen cookies lose value quickly. `IT OPS` [S1]
- Bring mobile DNS and network telemetry into the SIEM (MDM-enforced DNS filtering or a mobile threat defense agent) so that phone traffic off the corporate network is visible. `SOC` [S1]

Workarounds & compensating controls

- For executives, travelers and other high-risk users on iPhone, consider Apple Lockdown Mode, which restricts web engine features that browser exploits commonly rely on. The sources do not test Lockdown Mode against these chains, so treat it as hardening, not a guarantee. `LEADERSHIP`
- Where a phone cannot be updated straight away, restrict it to a filtered network or always-on DNS filtering with the listed domains blocked, and remove its access to mail and cloud apps until it is patched. `IT OPS` [S1]
- Block outbound TCP 8881 from guest and mobile network segments unless a business need exists. `IT OPS` [S1]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Sekoia (Threat Detection & Research): Poisoned Source: APT29 Watering Holes Targets Mobile Devices with N-day Exploits
Published 2026-11-04 · `A2` Completely reliable, probably true
Primary source and origin of all campaign indicators. Single-vendor research; attribution not confirmed by a government. Body and IOC table disagree on some hashes.

[S2] The Record: Russia-linked hackers target smartphones in watering hole attacks (Sekoia report coverage)
Published 2026-11-05 · `B2` Usually reliable, probably true
Summarizes Sekoia; adds that Sekoia is working with CERTs and that victim counts are unknown. No indicators.

[S3] Infosecurity Magazine: APT29 watering holes target iPhones and Android devices
Published 2026-11-04 · `B2` Usually reliable, probably true
States the moderate-to-high confidence level, Plerdy dates and CVE list. No indicators.

[S4] The Hacker News: APT29-Linked Hackers Hijack Web Analytics Script to Deliver Mobile Exploits
Published 2026-11-04 · `B2` Usually reliable, probably true
Repeats several Sekoia indicators and links the story to the separate DeadTag criminal campaign and Zimperium's Coruna domain count.

[S5] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-11-04 · `A1` Completely reliable, confirmed by other sources
Directly confirmed the CVE-2024-27834 entry (added 2026-11-04, due 2026-11-18). Other KEV dates were taken from the CISA ADP data in the CVE records.

[S6] FIRST: EPSS API scores for the eight CVEs
Published 2026-11-12 · `A2` Completely reliable, probably true
Scores dated 2026-11-12.

[S7] CVE Program (Apple CNA): CVE-2025-43529 record
Published 2025-12-17 · `A1` Completely reliable, confirmed by other sources
WebKit use-after-free; fixed versions; KEV added 2025-12-15.

[S8] CVE Program (Apple CNA): CVE-2026-20700 record
Published 2026-02-11 · `A1` Completely reliable, confirmed by other sources
Memory corruption; fixed in 26.3; KEV added 2026-02-12.

[S9] CVE Program (Chrome CNA): CVE-2025-14174 record
Published 2025-12-12 · `A1` Completely reliable, confirmed by other sources
ANGLE out-of-bounds access; KEV added 2025-12-12.

[S10] CVE Program (Apple CNA): CVE-2025-43510 record
Published 2025-12-12 · `A1` Completely reliable, confirmed by other sources
Fixed in iOS 18.7.2 and 26.1; KEV added 2026-03-20.

[S11] CVE Program (Apple CNA): CVE-2025-43520 record
Published 2025-12-12 · `A1` Completely reliable, confirmed by other sources
Kernel memory write; fixed in iOS 18.7.2 and 26.1; KEV added 2026-03-20.

[S12] CVE Program (Chrome CNA): CVE-2026-3910 record
Published 2026-03-12 · `A1` Completely reliable, confirmed by other sources
V8 flaw; fixed in Chrome 146.0.7680.75; KEV added 2026-03-13.

[S13] CVE Program (Qualcomm CNA): CVE-2025-27038 record
Published 2025-06-03 · `A1` Completely reliable, confirmed by other sources
Adreno GPU driver use-after-free; CVSS 7.5 from Qualcomm; KEV added 2025-06-03.

[S14] CVE Program (Apple CNA): CVE-2024-27834 record
Published 2024-05-13 · `A1` Completely reliable, confirmed by other sources
Pointer Authentication bypass; fixed in iOS 16.7.8 and 17.5; KEV added 2026-11-04.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-04-02	static.flux-telemetry[.]com registered; ad.starx-net[.]com follows on 3 April.	[S1]
2026-05-19	Lookalike domain america250[.]holiday registered.	[S1]
2026-06-18	Lookalike domain theowo[.]club registered.	[S1]
2026-08-26	edge-ord.clouds-stacks[.]com registered, one day before the Plerdy injection begins.	[S1]
2026-08-27	Plerdy tracker script begins serving the injected loader; this lasts until 3 September 2026.	[S1] [S3] [S4]
2026-09	A DarkSword kit sample is uploaded to VirusTotal (day not stated).	[S1]
2026-10	Sekoia finds the campaign in mid-October after spotting malicious code on a Ukrainian gas producer's website.	[S1] [S2] [S3]

Date	Event	Source
2026-11-04	Sekoia publishes Poisoned Source; CISA adds CVE-2024-27834 to the KEV catalog.	[S1] [S5] [S14]
2026-11-05	The Record reports that Sekoia is working with national CERTs to identify victims and disrupt the infrastructure.	[S2]
2026-11-18	CISA KEV due date for federal agencies to remediate CVE-2024-27834.	[S5]

Relevance to Indianapolis, Indiana & managed clients

No Indiana victim is named. The realistic exposure for Indiana is indirect. One compromised site belongs to a major US chemical industry trade association, and Indiana's chemical, pharmaceutical, plastics and wider manufacturing firms have staff who visit sites of that kind; the association is not named publicly, so members cannot yet check their own exposure. The America250 lookalike matters to state, county and city government staff, schools, universities and civic groups planning 250th anniversary events, who could have reached the cloned site through an invitation link. Because the scripts applied no victim filter, any out-of-date phone that loaded an affected page was exploited regardless of who owned it. For healthcare, education and small and mid-size businesses the main lesson is that personal and older phones with access to mail and cloud apps are a real path to stolen sessions: stolen cookies bypass multi-factor sign-in, and stolen Wi-Fi keys expose office networks. Managed IT service clients should expect a mobile patch compliance check, blocking of the listed infrastructure at DNS and firewall, a log search for the indicators, and, where a client hosts a public website, a review of its third-party scripts. Organizations with Ukrainian business ties or defense supply chain work, including those connected to federal and military facilities in the state, should treat the risk as higher.

Intelligence gaps

- Number and identity of compromised devices and how much data was taken are unknown; Sekoia did not determine either.
- Sekoia's full indicator set is restricted to its customers and to CERTs and law enforcement on request; the public list is partial and may be stale as infrastructure is taken down or rotated.
- The US chemical trade association and most other compromised sites are not named, so organizations cannot directly check whether staff visited them.
- Sekoia's article body and IOC table give different SHA-256 values for some stages (Class B /v1 and /v2, Class C stage 1) with no explanation.
- The exact role of the four redirect domains (ads-it-assets, cdn.adv-static, wpvortex-mod, assets-int) is not described beyond being redirect targets.
- How Plerdy and the individual websites were compromised is not stated, and no public statement from Plerdy was found.
- No government (CISA, NCSC, CERT-UA) attribution or advisory was found as of 2026-11-12; watch for one.
- Whether iOS 16-only devices have any fix for CVE-2025-43529 is unclear from the CVE record, and the Apple fix version for CVE-2025-14174 was not retrieved.
- KEV due dates for the seven older CVEs were not retrieved (all have passed); KEV membership for those was taken from CISA ADP data in the CVE records, not from the catalog file itself.

- Who built and supplies DarkSword and the Android chain is not established; Sekoia suspects a commercial surveillance vendor.

Other notes

- This report updates CTI-20261104-03 and CTI-20261105-03. The main change is the indicator list: Sekoia's write-up was reachable and its public indicators are now included.
- The briefing excerpt listed seven CVEs; Sekoia and Infosecurity Magazine also list CVE-2024-27834 (the Class A pointer authentication bypass), which CISA added to KEV on the day of publication.
- The briefing's points that a reboot ends the implant and that Lockdown Mode helps are not stated in Sekoia's article as fetched. The reboot point follows from the reported lack of persistence; Lockdown Mode is general Apple hardening guidance and is untested against these chains in the sources.
- Sekoia notes unused or dead code in the kits for CVE-2024-27808, CVE-2024-27833, CVE-2025-31277 and CVE-2025-24201, which points to reuse of a third-party exploit package.
- The Hacker News links the story to DeadTag, a separate criminal campaign that reuses expired domains behind old analytics and ad tags (more than 660 domains) to serve the Coruna kit (iOS 13 to 17.2.1) and DarkSword (iOS 18.4 to 18.7), and cites Zimperium's count of 608 domains serving Coruna-family code as of October 2026. That activity is not attributed to APT29.
- Sekoia found no evidence that the Ukrainian president, who reportedly stayed at Raffles London on 14 October 2026, was targeted through the hotel lookalike site.
- An Australian medical clinic site also carried the script; Sekoia regards it as unrelated to the targeting, which supports the view that some compromises were opportunistic.
- EPSS values are probabilities from FIRST dated 2026-11-12. CVSS scores for the Apple and Chrome CVEs come from CISA's ADP enrichment, not from the vendors.

CTI-20261112-03 v1.0 · Generated 2026-11-12 15:03 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.